

SIMATS ENGINEERING

ASSESSMENT TOOL 3 — Scenario-Based Assessment: Model Answers

Course Name: Ethical Hacking

Name: Mounnila S P

Course Code: ITA1406

Reg no:192511188

Course Outcome: CO2 — Footprinting Tools, DNS Zone Transfers, Social Engineering Attacks and Countermeasures

Topic 1 — Q1: Passive Footprinting for ABC Technologies

Suitable Tools and What Each Reveals

- WHOIS (whois command / WHOIS lookup services): reveals domain registration details — registrant/registrar, creation and expiry dates, and authoritative name servers — without touching the company's own infrastructure.
- theHarvester / Hunter.io: passively collects publicly listed employee email addresses from search engines and public data sources, useful for mapping personnel and department structure.
- BuiltWith / Wappalyzer: passively fingerprints the technology stack of the company's public website — CMS, web server, frameworks, analytics and marketing tools — by analyzing publicly served page content.
- Sublist3r / crt.sh (Certificate Transparency logs) / Amass: enumerates publicly exposed subdomains using passive sources (search engines, DNS aggregators, SSL certificate transparency records) without directly probing the target's servers.

How Each Tool Supports Competitive Intelligence

WHOIS data exposes organizational ownership and infrastructure history, useful for understanding vendor and hosting relationships. Email harvesting reveals organizational size and departmental structure, which is valuable both for competitive analysis and identifying potential social-engineering vectors. Technology-stack fingerprinting shows which vendors and platforms the company depends on, hinting at licensing costs, integration choices, and known vulnerabilities associated with that stack. Subdomain enumeration maps out the public attack surface, including staging or lesser-known services, giving a fuller picture of the organization's online footprint — all gathered purely through passive, publicly available sources.

Topic 2 — Q2: Verifying DNS Zone Transfer Misconfiguration

Command to Verify Zone Transfer

```
dig axfr @ns1.target.com target.com
```

(Equivalent alternatives: `host -t axfr target.com ns1.target.com`, or `nslookup -> server ns1.target.com -> ls -d target.com`)

If the Transfer Succeeds

The command returns the organization's complete DNS zone file, including A, MX, NS, CNAME, and TXT records for every host the DNS server is authoritative for.

How the Retrieved Records Aid Reconnaissance

- A/CNAME records reveal internal and external hostnames, including development, staging, or administrative subdomains not otherwise advertised publicly.
- MX records identify the organization's mail servers and mail provider, useful for planning phishing infrastructure or targeted email attacks.
- The complete subdomain list removes the need for brute-force subdomain guessing, letting an attacker directly target the weakest-looking system (e.g., an old test server) for further exploitation.

Topic 3 — Q3: Phishing Email Impersonating IT Department

Type of Social Engineering Attack

This is a Phishing attack — specifically a credential-harvesting phishing email that uses impersonation of the IT department and urgency ('urgent security update') as its core manipulation techniques. If personalized to specific employees, it would be classified as spear-phishing.

Countermeasures Employees Should Apply Before Responding

1. Verify the sender's actual email address/domain rather than trusting the displayed name — check for spoofed or look-alike domains.
2. Do not click the embedded link; instead navigate to the official IT portal manually or via a saved bookmark.
3. Hover over the link (without clicking) to inspect the real destination URL before deciding to proceed.

4. Contact the IT department directly through a known, official channel (phone extension, internal chat) to confirm whether the request is genuine.
5. Treat urgency and pressure language as a red flag — legitimate IT requests rarely demand immediate credential re-entry through an email link.
6. Report the email to the security team using the organization's 'Report Phishing' mechanism instead of ignoring or forwarding it casually.
7. Check for tell-tale signs such as generic greetings, spelling/grammar inconsistencies, and mismatched branding.
8. If a landing page is reached inadvertently, verify HTTPS and the exact domain name before ever entering credentials.

How These Actions Prevent Credential Theft

Verifying the sender and inspecting the link stop the attack before any interaction with the attacker's infrastructure occurs. Confirming the request through an independent, official channel neutralizes the impersonation, since the attacker has no control over that channel. Recognizing urgency as a manipulation tactic breaks the psychological pressure the attack relies on. Reporting the email — rather than silently ignoring it — allows the security team to block the sender and warn other employees, containing the threat organization-wide instead of leaving it to repeat against less-aware colleagues.